

# feelzlike.com: full site review, smoke and security test (round 2)

Reviewer: Sven | Date: 25 Sep 2026, 3pm AEST | Build: /assets/index-DXgXurMS.js | Repo commit: 5d6b5b25

Scope: I tested the live site from outside without signing in, and reviewed the code. I made no purchases and created no checkout sessions.

## Verdict

This round fixed most of what I raised. The site is in good shape for free users.

Two blockers remain before you switch purchases on:

- **Open-Meteo commercial licence.** A paid app needs one.
- **BILLING\_ORIGIN is not set, so checkout cannot work yet.**

Two policy decisions are also still open: the HTML security headers and the regional-price rule.

## Fixed and confirmed live

| #  | Item                    | Live result                                                                                                                    |
|----|-------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| 1  | Premium API enforced    | Signed out, /api/elevation-forecast returns 401 and /api/weather/{id} returns 7 days, not 14                                   |
| 2  | Snowy Mountains heights | Thredbo 1701, Perisher 1887 (mid-mountain)                                                                                     |
| 2  | Summit fallback         | Mt Buller 1590, Whistler Mountain 1429, Coronet Peak 1398 (all mid-mountain now)                                               |
| 2  | US heights unchanged    | Heavenly 2488, Jackson 2555, Stowe 874                                                                                         |
| 3  | Cache busting           | The server now snaps snowElevationM to the configured mid height. Values of 1, 1887 and 5000 all returned the same forecast    |
| 4  | Weather reliability     | A 200-resort sample at a normal pace: 199 returned 200 and 1 returned 404 (see below). Last round it was 260 errors out of 648 |
| 7  | OWM key                 | It is gone from the new build and not in the GitHub repo. The old bundle is no longer served                                   |
| 8  | CORS                    | evil.replit.app is no longer allowed, and unknown origins get 200 with no CORS permission (the 500 is gone)                    |
| 9  | Billing status          | Rate-limited to 30 per minute, with readiness and entitlement lookups cached                                                   |
| 12 | Promo times             | Now fixed Sydney times on both client and server                                                                               |
| 14 | /pricing                | Redirects to /premium, and upgrade links point to /premium                                                                     |

| #  | Item                | Live result                                                                                             |
|----|---------------------|---------------------------------------------------------------------------------------------------------|
| 15 | Whitefish note      | Removed                                                                                                 |
| 16 | Austria label       | Fixed                                                                                                   |
| 17 | 404 page            | Shows "page not found" with noindex, nofollow                                                           |
| 18 | Duplicate HSTS      | Removed                                                                                                 |
| —  | Signed-out /account | Now titled "your account" with a sign-in action                                                         |
| —  | Mobile (390x844)    | Clean, with no overlap and no console errors on Thredbo                                                 |
| —  | Access controls     | /api/account and /api/billing/status return 401, /api/admin returns 403, anonymous checkout returns 403 |

## Still open

### Launch blockers (before purchases go on)

1. **Open-Meteo commercial licence.** It isn't set up yet, and Replit correctly left this for you. The free tier does not allow commercial use ([Open-Meteo terms](#)); a subscription gives a commercial licence and API key ([pricing](#)).
2. **BILLING\_ORIGIN is not set.** My POST from <https://feelzlike.com> still got BILLING\_ORIGIN\_REQUIRED. Set it to <https://feelzlike.com>, then do one signed-in test checkout in Stripe test mode.
3. **Decide on regional pricing.** Buyers still pick their own billing country, and it defaults to Australia. A US buyer can pay AUD 5.99 including tax, about USD 3.90, instead of USD 5.99 plus tax. Replit kept this as a deliberate choice. Either accept it, or check the Stripe billing-address country in the webhook.

## Medium

4. **The HTML still has no security headers** apart from HSTS. There is no X-Frame-Options, CSP, nosniff or Permissions-Policy. Replit says the static site is served by the Replit hosting layer, not Express, so it can't add them from code. Options:
  - Ask Replit support about custom headers on static deployments.
  - Put Cloudflare (free plan) in front of the domain and add the headers there.
  - Serve the frontend through Express so helmet can add them.
5. **Rotate the OpenWeatherMap key.** It was public in earlier builds, so treat it as compromised. Move it to a private OWM\_API\_KEY secret, then remove the fallback code.
6. **The weather cache lives only in each server's memory.** It is lost on every restart or deploy. A cold start with traffic, like my round-1 sweep, can still exhaust the supplier. Consider a persistent cache (Postgres or Redis) and a small warm-up job for the top 50 resorts.

## Low

7. **Wrong forecast label for signed-out users.** They see the heading "extended (14-day)" but only get 7 days. Show "7-day" plus a "sign in for 14 days" prompt.
8. **Snowplanet returns 404.** `/api/weather/snowplanet` returns 404, but it is in the sitemap and marked `weatherEligible:true` in `/api/regions`. Either add a weather location or mark it not eligible and remove it from the sitemap.
9. **Leftover research text in the Schweitzer blurb.** It still reads like research notes: "despite a historically low snow season per research", plus an old opening-window note. Replit's lint only targeted Whitefish. Apply the "per research" check to every blurb.
10. **The webhook still returns 503 for a bad signature.** The code is fixed, but the webhook secret isn't configured yet, so it errors before the signature check. Recheck after the Stripe secrets are set. It should then return 400.
11. **Thredbo shows "ELEV 1737M".** That is neither the village (1365) nor the summit (2037). Show the village height, or label it clearly.
12. **Unknown URLs still return HTTP 200** (the page itself says not found and is `noindex`). That covers `/.env` too, which just shows the app shell, so nothing is exposed. This is a hosting-layer limit and low priority.
13. **The GAESA hosting cookie flags are unchanged.** This is a hosting-layer issue and low risk.

## Notes for Replit (paste in order)

1. Set `BILLING_ORIGIN=https://feelzlike.com` (no trailing slash) in production secrets. Then run one signed-in checkout and a portal session in Stripe test mode, and confirm the webhook grants and revokes access.
2. Once the Stripe webhook secret is set, confirm a bad Stripe-Signature returns 400 and a valid test event returns 200.
3. Add `OPEN_METEO_API_KEY` support using `https://customer-api.open-meteo.com` when the key is present (I am buying the commercial plan). Keep the free endpoint for development only.
4. Move the OpenWeatherMap key to a private `OWM_API_KEY` secret (I will rotate it), and remove the old compatibility fallback.
5. On forecast sections for signed-out users, change the "extended (14-day)" heading to "7-day forecast". Add an inline "sign in free to see 14 days" prompt.
6. Snowplanet: either add a weather location for snowplanet, or set `weatherEligible:false` and remove it from the sitemap.
7. Extend the blurb lint from Whitefish to all regions: fail the build on "per research", "treat as unverified", "no confirmed" or a warning emoji. Rewrite the Schweitzer description.
8. Thredbo header: show the village elevation (1365 m), or label it as "village" or "mid".
9. Persist the weather cache (Postgres table keyed by location id, with `fetchAt`), and warm the top 50 resorts every 30 minutes, so restarts don't cause a cold stampede.

10. Regional pricing: default the billing-country picker to the browser region, not AU. If I confirm, check `customer.address.country` against the charged currency in the webhook, and flag mismatches for review.
11. Tell me whether Replit static deployments support custom response headers. If not, I will add them at Cloudflare: `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy: geolocation=(self), camera=(), microphone=()`, and a report-only CSP.

### Actions for you (not Replit)

- Buy the Open-Meteo commercial plan.
- Rotate the OpenWeatherMap key.
- Decide the regional-price policy.
- Decide on headers: Replit support or Cloudflare.